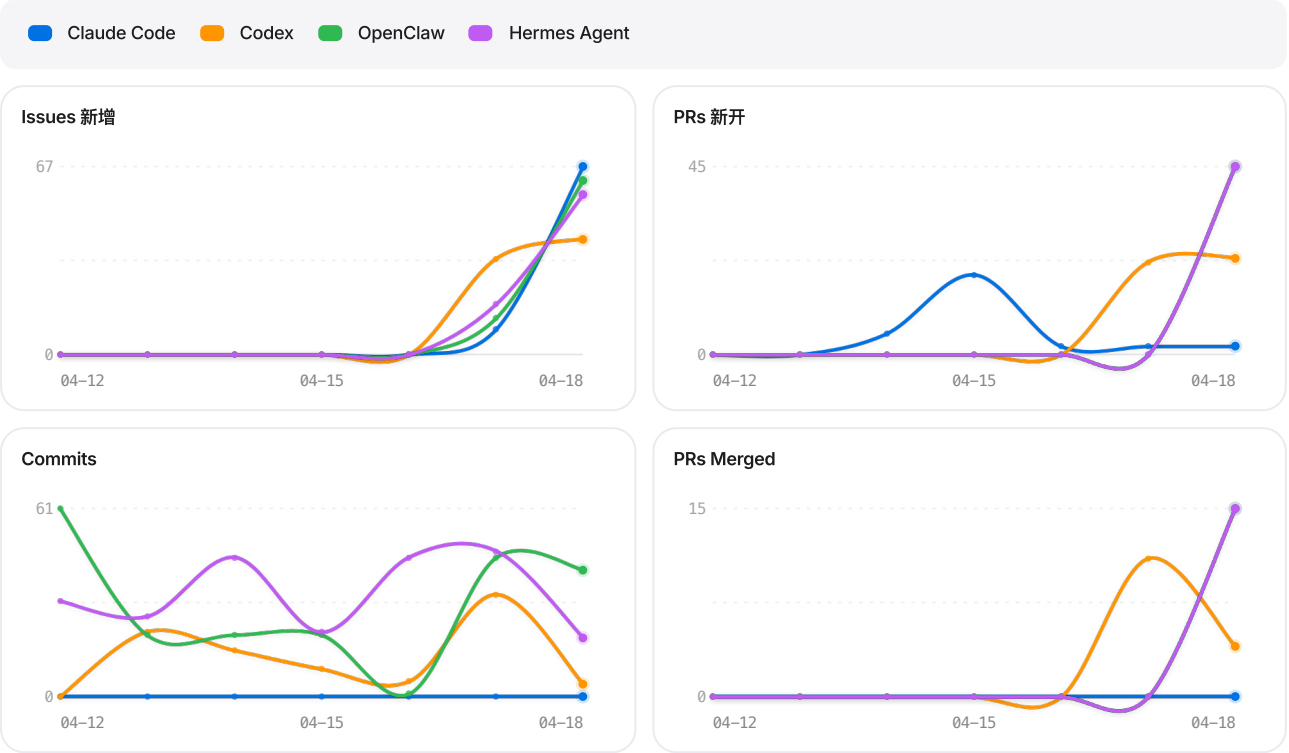
辛哥的开源风向

GitHub Daily · 2026-04-19

今日头条

今天最值得停下来看的信号横跨两个项目：Claude Code 同一天暴露了两个安全问题——claude-in-chrome MCP 可以无提示跨账号接管他人浏览器会话，文件历史快照功能会把 .env 私钥明文留在本地隐藏目录；Hermes Agent 当天就把 Claude Code 2.1.113 引入的危险命令检测规则（含 macOS `/private/` 路径绕过）移植进来。两件事拼在一起是一个不寻常的跨项目安全信号。如果你在用 Claude Code 的文件历史或 chrome MCP，今天先查清楚再说。

AI Agent 标杆项目动态



Claude Code

今日 Claude Code 的主线分两条，互不干扰。

技术侧：v2.1.113 把执行层从 JavaScript 包切换为原生二进制，Nix、Guix 等非标准 Linux 发行版因 ELF 解释器路径问题立即触发兼容性回归；v2.1.114 当天跟上热修复，顺带修了 Agent Teams 权限对话框崩溃。从发版到回归再到热修复不超过一个工作日，节奏快，代价是非主流发行版用户当了试验田。Nix/Guix 用户目前建议锁定 v2.1.114。

安全侧：两个问题同时浮出水面。其一，claude-in-chrome MCP 可在无任何提示的情况下操控他人账号的浏览器，跨账号权限边界没有守住；其二，文件历史快照会将 .env 等文件的明文内容留存在本地隐藏目录，私钥暴露路径比多数人意识到的要短。官方尚无公开说明，chrome MCP 先关掉比较稳。另有多 agent 并发场景下的父会话死锁，有完整复现路径，待修。

Codex

今日 Codex 最集中的工程量落在设备密钥基础设施上。四个关联 PR 一次性提交了协议定义、核心 crate、app-server 适配层，以及 macOS（Secure Enclave）、Windows（CNG/TPM）、Linux（TPM2）三套平台实现，意图是为本地设备绑定认证提供硬件级支撑——换句话说，Codex 在给"这台机器 = 这个用户"这个等式打地基。

配套动作：MCP 工具的权限 hook 把原有 Bash hook 的 payload 结构延伸进来；Plan Mode 新增"清空上下文后实现"路径，让规划对话和实现线程彻底解耦，不用把整段讨论带进生成阶段。24 小时内连发 alpha.8/9/10 三个预发布，团队显然处于密集冲刺。

OpenClaw

今日 OpenClaw 最值得标记的是一个高危稳定性 bug 的处置速度：weixin 插件 sidecar 进程误杀父级 gateway、触发无限重启循环的问题当天提、当天合入，修法是在 stale-pid 清理逻辑里把整条祖先 PID 链排除在外。cron 任务超时后遗留幽灵 task 行（生产环境有 29 个 stale_running 实例作为证据）也在排队等合。

功能侧有一个还在评审的大 PR：lab 实验性 prompt 覆盖层，支持 model-specific AGENTS.md addenda，首批含 GPT-5.4 调参包；同作者配套提交了 NO_REPLY 策略按会话类型分级控制。当前影响面最宽的未修问题是 OpenRouter base URL 被硬编码为 `/v1` 而非正确的 `/api/v1`，导致所有模型调用静默失败——用 OpenRouter 的先确认版本再说。

Hermes Agent

今日 Hermes Agent 的动作方向最清晰：基础设施可靠性是主线，功能扩展是副线，两条并跑。

可靠性侧：流式传输中途 stall 导致工具调用丢失不再静默退出；Signal typing 指标的无限重试被替换为指数退避；Telegram session 槽位的竞态 bug 当天报告、当天提 PR。另有一支分支明确标注"灵感来自 Claude Code 2.1.113"，把 macOS `/private/` 路径绕过等三条危险命令检测规则移植进来——说明 Hermes 团队在主动跟踪 Claude Code 的安全修订，这个习惯比多数 agent 项目认真。

功能侧两个主动架构决策：新增 `/steer` 指令，允许用户在 agent 运行期间于下一次工具调用结束后注入引导文本，不中断流程也不破坏 prompt cache；`execute_code` 默认模式从隔离临时目录切换为 project 模式，与 `terminal()` 共用相同 CWD 和解释器，直接针对弱模型反复混淆工作目录的问题——代价是执行隔离性降低，适不适合你的场景要自己判断。

GitHub 开源社区风向

Daily Trending Top 1 · thunderbird/thunderbolt

这是一个严肃工程，不是又一个 AI wrapper。Mozilla Thunderbird 团队亲自操刀，把"自托管 + 离线优先 + 模型无关"三件事放进同一个代码库认真做：前端 React 19 + Tauri 2 同时覆盖桌面和移动端，后端 Bun + Elysia，本地 SQLite 通过 PowerSync 反向同步 Postgres 作为真理源，认证层引入了 @noble/post-quantum 的后量子原语，配套三套部署方案（Docker Compose / Helm / Pulumi）。项目版本号已到 0.1.87，但公开仓库只有一条 squash commit，显然是内部库首发公域，开发历史不透明。

适合愿意自己运维整套 Postgres + PowerSync 栈的中小团队；不适合想下载即用的个人用户。两个硬限制要看清：README 自己承认仍依赖自家认证和搜索服务，E2E 加密尚未经过密码学审计且打了 warning。LibreChat、Jan、Chatbox 都在同一条赛道，Thunderbird 的差异点是品牌背书 + 真正的移动端原生支持 + PowerSync 离线同步，值不值得跟进取决于你有没有运维这套栈的人力。

Weekly Trending Top 10

#1 multica-ai/**andrej-karpathy-skills** — ★ 57.2k +42,267 / 周

把 Karpathy 那条吐槽 LLM 写代码毛病的推文整理成四条行为准则，做成 Claude Code 插件和 Cursor 规则两种安装方式，给写 AI agent 提示词的开发者用。

> 一句话 把 Karpathy 推文包成 Claude Code 插件，内容能用，但本质是一份能直接抄进自家 CLAUDE.md 的提示词。

#2 NousResearch/**hermes-agent** Python ★ 98.9k +47,053 / 周

Nous Research 出品的自托管 AI agent，目标是让一个跨模型的 agent 常驻在 VPS 或 serverless 环境里，可从 Telegram、Discord、Slack、Signal、CLI 等入口访问，并带技能自学和跨会话记忆。

> 一句话 严肃工程、研究实验室背书，但体积和单文件行数暴露出明显的沉重工程债，普通用户门槛不低。

#3 shiyu-coder/**Kronos** Python ★ 19.2k +6,511 / 周

一个为金融 K 线（OHLCV）序列预训练的 decoder-only 基础模型，作者是清华团队，论文已被 AAAI 2026 接收，给做量化研究、策略开发、时间序列预测实验的人用。

> 一句话 严肃学术项目，AAAI 2026 中稿带代码和权重，适合量化研究者实验，不是能直接上生产的策略系统。

#4 multica-ai/**multica** TypeScript ★ 16.0k +10,056 / 周

一个把 Claude Code/Codex/Gemini/Cursor Agent 等编码 Agent 当成团队成员、按 issue 分配任务并追踪执行的开源协作平台，定位是 "给 AI-native 小团队用的 Linear"。

> 一句话 严肃工程，Linear 式 AI agent 协作平台，要自托管得准备 Postgres+daemon+Docker 一整套，门槛不低。

#5 thedotmack/**claude-mem** TypeScript ★ 62.2k +14,033 / 周

给 Claude Code 用的会话记忆插件：用生命周期 hook 抓取工具调用和对话，用 SQLite + Chroma 做本地存储与检索，让新会话启动时自动注入过往上下文。

> 一句话 Claude Code 生态里做得最认真的一个本地记忆方案，工程完整度高但依赖链也最长。

#6 microsoft/**markitdown** Python ★ 112k +13,214 / 周

微软维护的通用文件转 Markdown 工具，覆盖 PDF、Office、图片、音频、YouTube、Outlook .msg 等十几种格式，定位是喂给 LLM 前的文档预处理管道。

> 一句话 微软维护的多格式文档→Markdown 管道，MCP、插件、云端 OCR 后端配齐，LLM 文档预处理场景里完成度最高的一个。

#7 OpenBMB/**VoxCPM** Python ★ 14.5k +5,786 / 周

OpenBMB 开源的 tokenizer-free TTS 系统 VoxCPM2，2B 参数、基于 MiniCPM-4 主干，支持 30 种语言的语音合成、声音设计和声纹克隆，输出 48kHz 音频。

> 一句话 面壁系严肃 TTS 工程，2B 参数 + 30 语言 + 48kHz 是真材实料，门槛在 CUDA 卡和 HF 权重下载。

#8 lsdefine/**GenericAgent** Python ★ 4.2k +2,375 / 周

一个单仓 Python 实现的自主 agent 框架，核心约 3K 行，对接多家 LLM，给用户本机浏览器、终端、文件系统、键鼠和 ADB 手机的执行权，靠逐步沉淀技能库来迭代自己。

> 一句话 思路有料的极简自演化 agent 框架，China-first 场景打得深，但仓库历史和营销口径对不上，落地前得自己掂量信任度。

#9 virattt/**ai-hedge-fund** Python ★ 56.1k +4,941 / 周

一个用 LangGraph 编排 19 个"投资人"智能体（巴菲特、芒格、Burry、Cathie Wood、Taleb 等）辩论选股的多 agent 框架，带 CLI、FastAPI 后端和 ReactFlow 可视化前端，作者明确标注仅用于教育演示，不实际下单。

> 一句话 19 个名人 agent 是噱头，但作为 LangGraph + 全栈 + 可视化编排的完整参考实现，工程骨架比噱头值钱。

#10 EvoMap/**evolver** JavaScript ★ 4.9k +2,082 / 周

一个 Node.js CLI 工具，挂在 Claude Code / Cursor / OpenClaw 的 hooks 里，扫描 agent 运行日志、识别失败模式、产出"进化 prompt"，并通过本地 Proxy 与 evomap.ai 的 Hub 同步技能资产。

> 一句话 架构想法不轻，但 GPL 仓库里塞混淆代码、单 commit 起手、配一篇"Hermes 抄我们"的檄文，可信度自损。

三类读者怎么读

- **开发者**：今天先查 Claude Code 会话目录下的隐藏文件夹，确认 .env 等敏感文件有没有被历史快照捕获；Nix/Guix 用户锁定 v2.1.114，chrome MCP 没有官方安全说明前先禁用。
- **创业者**：Codex 的硬件设备密钥基础设施和 Thunderbolt 的离线优先自托管路线指向同一个方向——把 AI 工具的数据和认证留在客户侧。这个方向有没有你的产品机会，可以拿去和几个企业客户聊聊需求强度。
- **投资者**：Hermes Agent 本周增 47k stars，RL 数据回流管线和 serverless 持久化是当前 agent 项目里少见的差异组合；但 run_agent.py 单文件一万两千行是工程硬伤，现阶段看势能信号比看代码质量更合理，实测数据出来前保持观望。